Security & Privacy Disclosure, Final Report

X (com.twitter.android)

X’s Android app ships a bank-account-linking and payments stack plus a facial-biometric liveness SDK, both undisclosed to EU users under a social-media consent framework, and routes financial queries to xAI, a separate legal entity, unresolved through 119 days and a 28-day-overdue embargo, with zero substantive reply of any kind

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 19 SEPTEMBER 2026, EIGHT FINDINGS REMAIN UNADDRESSED

Target	X Corp (formerly Twitter, Inc.), social media platform, and xAI Corp, a separate legal entity processing Grok financial queries
Package	com.twitter.android
Platform Audited	Android · v12.1.1-release.0 (versionCode 312011000), static analysis of the production APK
Initial Disclosure (R1)	2026-06-20 (REF com.twitter.android)
Disclosure / Embargo Date	2026-09-19
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	8 (2 Critical, 6 High)
Correspondence	5 messages sent by RFI-IRFOS across two threads, 1 automated bot acknowledgment received, 0 substantive replies to any of the eight findings
Authorities BCC'd / CC'd	Austrian Datenschutzbehoerde (DSB) · CERT.at · Irish Data Protection Commission (X Corp's EU lead supervisory authority)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6

4.1 C1: Very AI facial biometric liveness-detection SDK embedded in a social media app with no disclosed purpose or named processor . . . 6

4.2 C2: Full bank-account-linking and payments stack, plus Grok native financial-query interface, routes data to xAI Corp without naming it as a recipient 7

4.3 H1: Screen-capture infrastructure (FOREGROUND_SERVICE_MEDIA_PROJECTION + SYSTEM_ALERT_WINDOW) undisclosed beyond the DM-screenshot-detection use case . . . 8

4.4 H2: Braze behavioral-targeting platform (2,578 classes) not named as a recipient in EU consent documentation . . . 8

4.5 H3: Grok's content policy is entirely server-side, making Art. 22(3) meaningful-logic disclosure structurally impossible to verify . . . 9

4.6 H4: MANAGE_OWN_CALLS telephony infrastructure undisclosed as a collected data category . . . 9

4.7 H5: Complete Privacy Sandbox ad-attribution suite requires ePrivacy Art. 5(3) consent not evidenced in the app . . . 10

4.8 H6: READ_CONTACTS cross-referenced with the bank-linking infrastructure creates an undisclosed financial inference graph over non-consenting third parties . . . 10

5 Impact Analysis 11

6 The Complete Chain: An Automated 'Do Not Reply' Notice Is the Entire Correspondence Record 11

7 Data Protection — Article by Article 12

8 Regulatory & Legal Landscape 12

9 Indicators of Compromise 13

10 Disclosure Timeline & Outcome 13

11 Residual Risk & Recommendations 14

Executive Summary

X Corp operates the social media platform X (formerly Twitter) and owns the Grok AI assistant integrated into its Android app. xAI Corp, which processes Grok's financial queries, is a separate legal entity from X Corp. RFI-IRFOS pulled com.twitter.android v12.1.1-release.0 from a production device on 20 June 2026 and performed static analysis only: no backend access, no account creation.

Static analysis identified eight findings: two CRITICAL and six HIGH. The APK bundles a complete bank-account-linking and payments infrastructure, Plaid (3,456 classes) and Stripe (8,102 classes) plus a native X Payments module (3,433 classes), together with Grok transaction-search proto classes that give Grok a native interface to users' bank transaction data. xAI Corp, which processes these queries, is not named as a financial-data recipient in X's EU consent framework. Separately, three registered Activities (org.very.sdk.ScanActivity, LivenessCheckActivity, LivenessErrorActivity) confirm a fully integrated facial biometric liveness-detection SDK from Very AI, special-category data under Art. 9 GDPR, with no disclosed purpose on a social media app and no named processor in the consent framework. Six further HIGH findings cover undisclosed screen-capture infrastructure, an undisclosed behavioral-targeting SDK (Braze, 2,578 classes), Grok's structurally opaque server-side content policy, undisclosed telephony infrastructure, a complete Privacy Sandbox ad-attribution suite, and a contact-import feature that cross-references the social graph with the financial-linking infrastructure.

RFI-IRFOS disclosed these findings on 20 June 2026 to security@x.com, BCC the Austrian DSB, CERT.at, and the Irish Data Protection Commission (X Corp's EU lead supervisory authority), stating an explicit embargo of 19 September 2026 in the initial message itself. X has never sent a single substantive or even procedural human reply across five messages over 90 days; the only response of any kind was an automated 'how to contact Twitter user support and security teams, do not reply to this message' notice. RFI-IRFOS sent further messages restating the findings on 9 August, 24 August, 31 August, and 12 September 2026, the last of these seven days before the stated embargo. The embargo passed 28 days ago with all eight findings unaddressed and no reply of any kind ever received.

ID	Severity	Title
C1	CRITICAL	Very AI facial biometric liveness-detection SDK embedded in a social media app with no disclosed purpose or named processor
C2	CRITICAL	Full bank-account-linking and payments stack, plus Grok native financial-query interface, routes data to xAI Corp without naming it as a recipient
H1	HIGH	Screen-capture infrastructure (FOREGROUND_SERVICE_MEDIA_PROJECTION + SYSTEM_ALERT_WINDOW) undisclosed beyond the DM-screenshot-detection use case
H2	HIGH	Braze behavioral-targeting platform (2,578 classes) not named as a recipient in EU consent documentation

ID	Severity	Title
H3	HIGH	Grok's content policy is entirely server-side, making Art. 22(3) meaningful-logic disclosure structurally impossible to verify
H4	HIGH	MANAGE_OWN_CALLS telephony infrastructure undisclosed as a collected data category
H5	HIGH	Complete Privacy Sandbox ad-attribution suite requires ePrivacy Art. 5(3) consent not evidenced in the app
H6	HIGH	READ_CONTACTS cross-referenced with the bank-linking infrastructure creates an undisclosed financial inference graph over non-consenting third parties

Subject & Operator Context

X Corp operates one of the world's largest social media platforms. Its Android app integrates Grok, an AI assistant built by xAI Corp, a separate legal entity from X Corp under common ownership. The app also integrates a full bank-account-linking and payments stack and a facial-biometric liveness-verification SDK, neither of which is a function a reasonable EU user would expect from a consent screen presented as 'connecting with others on X.'

The structural issue common to every finding in this report is the same: X's EU consent framework is built and presented as covering a social media and communications service. The infrastructure actually shipped in the production APK extends materially beyond that scope, into financial services, biometric identity verification, and a cross-entity AI data pipeline, with none of the additional recipients, purposes, or legal bases disclosed to the people whose data is actually being processed.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 20 June 2026 to security@x.com, BCC the Austrian Datenschutzbehoerde (DSB), CERT.at, and the Irish Data Protection Commission (Irish DPC, X Corp's EU lead supervisory authority under the GDPR one-stop-shop mechanism), stating the embargo date of 19 September 2026 explicitly in the message itself, twice.

The only response received across the entire 90-day disclosure window and five messages was a single automated notice on 9 August 2026, stating 'do not reply to this message, as your reply won't reach the security team,' and that reports sent via this channel would not reach X's security or Grok teams. No human acknowledgment, question, denial, or substantive engagement of any kind was ever received, from X Corp, xAI Corp, or any department of either. RFI-IRFOS sent further follow-up messages on 24 August, 31 August, and 12 September 2026, each restating the eight findings and escalating the day count; the Irish DPC's own automated contact-channel reply on 24 August 2026 clarified only that its AI Act market-surveillance inbox does not accept GDPR queries through that specific channel, a procedural note unrelated to the substance of any finding. The stated embargo of 19 September 2026 passed 28 days before this report's publication date, with the correspondence record showing zero substantive replies across both X Corp and xAI Corp.

Findings

C1: Very AI facial biometric liveness-detection SDK embedded in a social media app with no disclosed purpose or named processor

CRITICAL (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 7.9) — undisclosed Art. 9 facial biometric processing with no named processor in the EU consent framework, blast-radius escalated from HIGH

```
AndroidManifest.xml
  org.very.sdk.ScanActivity
  org.very.sdk.LivenessCheckActivity
  org.very.sdk.LivenessErrorActivity

Supporting smali:
  org.very.liveness.VeryAILiveness      -- SDK entry point
  org.very.liveness.VeryLivenessConfig  -- sdkKey, themeMode
  156 total classes, org.very.sdk + org.very.liveness

Vendor: Very AI (very.org) -- facial liveness / anti-spoofing
Not named as a processor anywhere in EU consent documentation
```

Impact: RFI-IRFOS blast-radius escalation: raised from HIGH/7.9 to CRITICAL because this is not an incidental biometric permission, it is a fully integrated facial liveness-detection and anti-spoofing pipeline (three registered Activities, 156 classes across org.very.sdk and org.very.liveness) in an app whose stated purpose is social media and communications. Very AI is not named as a biometric data processor anywhere in X's EU consent documentation, no legal basis for Art. 9 special-category processing is specified, and no retention period for biometric liveness captures is disclosed. The VeryLivenessConfig class requiring an sdkKey confirms active provisioning, not a dormant dependency.

C2: Full bank-account-linking and payments stack, plus Grok native financial-query interface, routes data to xAI Corp without naming it as a recipient

CRITICAL (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 7.9) — undisclosed financial-services processing and cross-entity AI data transfer under a social-media consent framework, blast-radius escalated from HIGH

```
Plaid: 3,456 classes (com.plaid.internal, com.plaid.link)
  PlaidFileProvider, LinkRedirectActivity, LinkActivity
  Deep link scheme registered: plaid://

Stripe: 8,102 classes (payment processing)

X Payments (native): 3,433 classes, com.x.payments
  Protos: TransactionMetadata, SettledTransactions,
  CheckDepositTransactionMetadata, PaymentCreateWireComponent

Grok financial-query protos:
  GrokTransactionSearchFeedbackResponse
  GrokTransactionSearchNavigationIntent
  InitiateGrokTransactionSearchResponse
  GrokTransactionSearchStatus

Processor: xAI Corp -- separate legal entity from X Corp,
not named as financial-data recipient in EU consent framework
```

Impact: RFI-IRFOS blast-radius escalation: raised from HIGH/7.9 to CRITICAL because the scale and sensitivity of the data involved exceeds a routine undisclosed-SDK finding. Plaid (3,456 classes, registered LinkActivity + plaid:// deep link scheme), Stripe (8,102 classes), and a native X Payments module (3,433 classes, protos covering wire transfers, check deposits, and settled transactions) together constitute a complete bank-account-linking and payments platform. Grok transaction-search proto classes (GrokTransactionSearchFeedbackResponse, InitiateGrokTransactionSearchResponse, and others) give Grok a native query interface to this transaction data, processed by xAI Corp, a separate legal entity from X Corp not named as a financial-data recipient anywhere in X's EU consent documentation. EU users consenting to a social network are, without being told, also consenting to bank-account linking, wire transfers, and an AI assistant's access to their transaction history.

H1: Screen-capture infrastructure (FOREGROUND_SERVICE_MEDIA_PROJECTION + SYSTEM_ALERT_WINDOW) undisclosed beyond the DM-screenshot-detection use case

HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.1) — undisclosed screen-recording capability combined with overlay permission

```
android.permission.FOREGROUND_SERVICE_MEDIA_PROJECTION
android.permission.DETECT_SCREEN_CAPTURE
android.permission.SYSTEM_ALERT_WINDOW

DETECT_SCREEN_CAPTURE use case (DM screenshot notice): disclosed
FOREGROUND_SERVICE_MEDIA_PROJECTION use case: not disclosed
```

Impact: FOREGROUND_SERVICE_MEDIA_PROJECTION enables the app to initiate screen recording as a foreground service, capturing everything visible on the display including content from other apps, notifications, and keyboard input. SYSTEM_ALERT_WINDOW enables drawing over other applications. DETECT_SCREEN_CAPTURE's use case, DM screenshot notification, is disclosed and legitimate; the screen-recording-initiation use case enabled by FOREGROUND_SERVICE_MEDIA_PROJECTION is not disclosed anywhere in X's EU privacy notice.

H2: Braze behavioral-targeting platform (2,578 classes) not named as a recipient in EU consent documentation

HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.1) — undisclosed third-party behavioral-targeting recipient

```
com.braze -- 2,578 classes across multiple dex files
AndroidManifest.xml: com.braze.BrazeFlushPushDeliveryReceiver

Collects: behavioral event streams, session data, device IDs
Use: cross-channel targeting (push, in-app, email)
Not named as a recipient in EU consent documentation
```

Impact: 2,578 smali classes from com.braze, plus a registered manifest receiver (com.braze.BrazeFlushPushDeliveryReceiver), confirm an active Braze customer-engagement integration collecting behavioral event streams, session data, and device identifiers to build user profiles for cross-channel push, in-app, and email targeting. Braze Inc. is not identified as a named recipient anywhere in X's standard EU consent disclosure.

H3: Grok's content policy is entirely server-side, making Art. 22(3) meaningful-logic disclosure structurally impossible to verify

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N, 7.3) — automated content-moderation logic that cannot be independently verified by design

```
GrokWebActivity / GrokWebFragment -- WebView wrapping
  assets/www/index.html, model served via server-side API

All system prompts, content filters, topic restrictions:
  server-side, dynamically served, not present in the APK

GrokDataSharingSettings / GrokDataSharingSettingViewModel --
  dedicated settings flow for xAI Corp training-data sharing
```

Impact: Grok is implemented via GrokWebActivity / GrokWebFragment loading the model interface through a WebView against a bundled index.html. All system prompts, content policies, topic restrictions, and model configuration are server-side and dynamically served, nothing is verifiable from the APK, and Art. 22(3) requires meaningful information about the logic involved in automated processing that significantly affects users. GrokDataSharingSettings confirms a dedicated flow for whether conversation data is shared with xAI Corp, a separate legal entity, for model training, which itself constitutes a data transfer requiring disclosure under Art. 13(1)(e) and an independent legal basis. Static analysis cannot verify claims about injected bias in Grok's responses; what is verifiable is that the architecture makes independent verification impossible by design, which is itself a transparency violation.

H4: MANAGE_OWN_CALLS telephony infrastructure undisclosed as a collected data category

HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.1) — undisclosed call-metadata collection

```
android.permission.MANAGE_OWN_CALLS

Enables: VOIP calls via system telecom infrastructure,
call-log integration, call-audio routing
Call metadata collection: not disclosed as a data category
```

Impact: android.permission.MANAGE_OWN_CALLS is declared, enabling VOIP calls routed through the system telecom stack, call-log integration, and call-audio routing (X calling / Spaces audio). Call metadata, who called whom, when, for how long, is not disclosed as a collected data category anywhere in X's EU privacy notice.

H5: Complete Privacy Sandbox ad-attribution suite requires ePrivacy Art. 5(3) consent not evidenced in the app

HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.1) — complete device-ID, attribution, and interest-profiling stack

```
android.permission.ACCESS_ADSERVICES_AD_ID
android.permission.ACCESS_ADSERVICES_ATTRIBUTION
android.permission.ACCESS_ADSERVICES_TOPICS
com.google.android.gms.permission.AD_ID
com.google.android.finsky.permission.BIND_GET_INSTALL_REFERRER_SERVICE
```

Impact: ACCESS_ADSERVICES_AD_ID, ACCESS_ADSERVICES_ATTRIBUTION, and ACCESS_ADSERVICES_TOPICS are declared together with Google's AD_ID permission and the install-referrer binder service, constituting the complete Privacy Sandbox ad-attribution stack: device-ID linkage, install-referrer attribution, interest-based topic targeting, and conversion measurement. ePrivacy Directive Art. 5(3) requires freely given, specific, informed consent prior to accessing or writing to device storage or identifiers for EU users; no such consent gate was identified ahead of this permission cluster's use.

H6: READ_CONTACTS cross-referenced with the bank-linking infrastructure creates an undisclosed financial inference graph over non-consenting third parties

HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 7.1) — contact import combined with financial data creates inference risk over third parties who never consented

```
android.permission.READ_CONTACTS
Stated purpose: "Find people you know"

Combined with C2 (Plaid bank-account linking): creates a
financial-inference graph over imported, non-consenting
third-party contacts not disclosed at collection time
```

Impact: android.permission.READ_CONTACTS is declared; X's stated use case is finding people a user knows. For a user who has also linked a bank account via the C2 payments infrastructure, their imported contact list links individuals who have not installed X, have not consented to any X processing, and may now be connected in X's social graph to a payments customer. This contact-import plus financial-linking combination creates a cross-referencing and inference capability over non-consenting third parties that is not disclosed at the point of collection.

Impact Analysis

The two CRITICAL findings in this report both concern data categories materially outside what an EU user consents to when opening a social media app: facial biometric identity data (C1) and complete bank-account access plus an AI assistant's native query interface to transaction history, processed in part by a separate legal entity (C2). Both findings carry a blast-radius escalation from their base HIGH/7.9 CVSS score because the data sensitivity and the cross-entity data-flow structure exceed what a routine undisclosed-SDK finding represents.

The six HIGH findings compound this picture: undisclosed screen-recording capability, an undisclosed behavioral-targeting platform, a content-moderation system that is structurally impossible to verify from outside the company, undisclosed telephony infrastructure, a complete ad-attribution stack, and a contact-import feature that, combined with the bank-linking infrastructure in C2, creates an inference graph over people who never installed the app at all.

What distinguishes this case from others in this disclosure series is the complete absence of any human engagement whatsoever: not a denial, not a deflection, not even a generic customer-service acknowledgment. The only reply received in 90 days and five messages was an automated notice stating that the channel used does not reach X's security or Grok teams at all.

The Complete Chain: An Automated 'Do Not Reply' Notice Is the Entire Correspondence Record

Step 1 — Disclosure sent with an explicit embargo stated twice: RFI-IRFOS sends the full findings to security@x.com on 20 June 2026, BCC the Austrian DSB, CERT.at, and the Irish DPC, stating 'embargo: 2026-09-19' and 'disclosure: 2026-09-19' directly in the message body and signature.

Step 2 — Fifty days pass in total silence: RFI-IRFOS sends a follow-up on 9 August 2026, fifty days after the original disclosure, noting zero replies to that point.

Step 3 — The only reply X ever sends is an automated redirect: Also on 9 August 2026, security@x.com auto-responds with a notice titled 'How to Contact Twitter User Support and Security Teams,' stating explicitly that replies to this channel will not reach the security team and that reports sent this way will not reach the relevant teams at all.

Step 4 — Two further follow-ups, zero further replies: RFI-IRFOS sends messages on 24 August and 31 August 2026, the latter noting seventy-two days and six total messages with still no substantive reply of any kind. The Irish DPC's own contact channel replies the same day as the 24 August message, but only to clarify a procedural point about its AI Act market-surveillance remit, unrelated to any of the eight findings.

Step 5 — Embargo reached with seven days' notice, then passed in silence: A final follow-up on 12 September 2026 notes eighty-four days and an embargo in seven days. The stated embargo of 19 September 2026 passes with the correspondence record unchanged: one automated 'do not reply' notice, nothing else, ever.

Step 6 — Publication: This report publishes 28 days after the embargo date, on the terms stated from the first message.

Across every other case in this disclosure series with any reply at all, there was at minimum

a customer-service acknowledgment or a bot ticket number. X's only response, across five messages and 90 days, told RFI-IRFOS the channel it used does not reach anyone who could act on the report.

Data Protection — Article by Article

Art. 9(1) GDPR — Special categories of personal data: C1's Very AI facial-liveness processing handles special-category biometric data with no Art. 9(2)(a) explicit consent mechanism identified.

Art. 5(1)(b) GDPR — Purpose limitation: C2's bank-account linking, payments, and Grok financial-query infrastructure falls materially outside the stated purpose of a social-media and communications service.

Art. 13(1)(e) GDPR — Named recipients: C1 (Very AI), C2 (xAI Corp, Plaid Inc., Stripe Inc.), and H2 (Braze Inc.) are each undisclosed recipients not named in X's EU consent documentation.

Art. 22(1)(3) GDPR — Automated decision-making, meaningful information about the logic: H3's entirely server-side Grok content policy makes this disclosure obligation structurally impossible to satisfy from the shipped app.

ePrivacy Directive Art. 5(3) — Consent for device storage and identifier access: H5's complete Privacy Sandbox ad-attribution stack requires prior consent not evidenced in the app's available disclosures.

Regulatory & Legal Landscape

X Corp's EU lead supervisory authority under the GDPR one-stop-shop mechanism is the Irish Data Protection Commission, BCC'd on the original disclosure and on every subsequent follow-up. The Austrian DSB and CERT.at were BCC'd as a matter of standard procedure given RFI-IRFOS's Austrian registration.

Fine exposure under GDPR: Art. 83(5) applies to the Art. 9 special-category processing in C1 and the Art. 22 automated-processing transparency failure in H3, up to EUR 20,000,000 or 4% of X Corp's total worldwide annual turnover, whichever is higher. Art. 83(5) also applies to C2's undisclosed cross-entity financial-data transfer to xAI Corp under Art. 46. That X Corp's only response across five messages and 90 days was an automated notice stating the report channel does not reach its security team is itself a fact relevant to any regulator assessing institutional engagement with a disclosed Art. 9 and Art. 22 finding set of this scale.

Indicators of Compromise

The following identifiers, SDK packages, and permissions were extracted from the production APK (v12.1.1-release.0, versionCode 312011000) via static analysis only. No X Corp or xAI Corp servers, accounts, or infrastructure were probed.

```
C1 -- org.very.sdk/, org.very.liveness/ (Very AI) -- facial
  biometric liveness verification, 156 classes

C2 -- com.plaid.internal/, com.plaid.link/ (3,456 classes),
  Stripe (8,102 classes), com.x.payments/ (3,433 classes),
  Grok transaction-search proto classes

H1 -- FOREGROUND_SERVICE_MEDIA_PROJECTION, SYSTEM_ALERT_WINDOW
H2 -- com.braze/ (2,578 classes)
H3 -- GrokWebActivity/GrokWebFragment, GrokDataSharingSettings
H4 -- MANAGE_OWN_CALLS
H5 -- ACCESS_ADSERVICES_AD_ID/ATTRIBUTION/TOPICS
H6 -- READ_CONTACTS (cross-referenced with C2)
```

Disclosure Timeline & Outcome

2026-06-20 Initial disclosure sent to security@x.com, embargo of 2026-09-19 stated twice in the message. BCC: Austrian DSB, CERT.at, Irish DPC.

2026-08-09 Follow-up sent, fifty days since the original disclosure, zero replies to that point. Same day: an automated ‘do not reply, this channel does not reach the security team’ notice is received, the only response ever received.

2026-08-24 Further follow-up, fifty-nine days since the original disclosure. The Irish DPC’s contact channel replies with a procedural note on its AI Act remit, unrelated to any finding.

2026-08-31 Further follow-up, seventy-two days since the original disclosure, six total messages sent, still no substantive reply.

2026-09-12 Final follow-up before the embargo, eighty-four days since the original disclosure, embargo in seven days.

2026-09-19 Stated embargo date reached. The correspondence record shows zero substantive replies of any kind.

2026-10-17 This report published, 28 days after the embargo date. All eight findings confirmed unaddressed on the basis of the correspondence record.

Residual Risk & Recommendations

C1 – Immediate: Name Very AI as a biometric data processor in the EU consent framework, specify the Art. 9(2)(a) legal basis and retention period for liveness captures, or remove the SDK if no shipped feature requires it.

C2 – Immediate: Name xAI Corp, Plaid Inc., and Stripe Inc. as recipients in the EU consent framework for any user who enables financial features; implement a separate, explicit consent flow for bank-account linking distinct from the base social-media consent; document an Art. 46 safeguard for the cross-entity transfer to xAI Corp.

H1 through H6 – Immediate: disclose the screen-recording initiation use case (H1), name Braze as a recipient (H2), provide meaningful information about Grok's content-moderation logic to the extent Art. 22(3) requires (H3), disclose call-metadata collection (H4), obtain ePrivacy Art. 5(3) consent ahead of the Privacy Sandbox ad-attribution stack (H5), and disclose the contact-import/financial cross-referencing capability (H6).

Across all findings: establish a disclosure-intake process capable of recognizing and routing a GDPR/security disclosure addressed to security@x.com. The current automated response, stating the channel does not reach the security team at all, means a report of this severity, addressed exactly where X's own public-facing security contact page directs it, never reached a human being in 90 days.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static root-level analysis of the published application using publicly available tooling. No X Corp or xAI Corp servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF X-TWITTER-2026.